

AI-Driven Risk Assessment for Critical Infrastructure Based on IEC 62443 Using Large Language Models

Andreas Bernhard

andreas@bernhard.im

Independent Researcher <https://orcid.org/0009-0001-3753-7085>

Mathias Pfister

Independent Researcher <https://orcid.org/0009-0007-1976-7622>

Research Article

Keywords: Risk Assessment, Industrial Control Systems, IEC 62443, Artificial Intelligence, Cybersecurity

Posted Date: March 9th, 2026

DOI: <https://doi.org/10.21203/rs.3.rs-9050939/v1>

License:   This work is licensed under a Creative Commons Attribution 4.0 International License.

[Read Full License](#)

Additional Declarations: The authors declare no competing interests.

AI-DRIVEN RISK ASSESSMENT FOR CRITICAL INFRASTRUCTURE BASED ON IEC 62443 USING LARGE LANGUAGE MODELS

PREPRINT, COMPILED MARCH 6, 2026

Andreas Bernhard ¹* and Mathias Pfister ¹

¹Independent Researcher

ABSTRACT

ICSs in critical infrastructure require structured cybersecurity risk assessments to derive defensible security requirements for industrial automation systems. Recent advances in LLMs raise the question of whether such systems can support early-phase IEC 62443-3-2-aligned risk assessment work and, critically, how generated assessment artifacts vary across different models. This paper presents a qualitative *AI-vs.-AI* comparison of IEC 62443 risk assessment artifacts produced under controlled, single-pass conditions using a common system model and a standardized IEC 62443-3-2-based task set. We compare outputs along three axes: (i) model evolution within a single family, (ii) cross-vendor comparison of frontier-class models, and (iii) a premium-tier model against the frontier baseline. The study evaluates assessment structure, architectural coherence, and internal consistency relative to IEC 62443 principles and across models, rather than against an external ground truth. Results reveal notable differences in threat scenario structuring, zoning granularity, SL-Ts assignment, and implicit operability assumptions. We discuss what these findings suggest for the use of LLMs as decision-support tools in early-stage ICS risk assessment.

Keywords Risk Assessment · Industrial Control Systems · ISA/IEC 62443 · Artificial Intelligence · Cybersecurity

1 INTRODUCTION

Industrial Control Systems (ICSs) form the backbone of critical infrastructure and are increasingly interconnected, expanding both the attack surface and the engineering effort required to derive and justify appropriate protections. IEC 62443-3-2 [1] provides a structured approach for deriving cybersecurity requirements by defining threat scenarios, estimating risk, and mapping results to Security Level Targets (SL-Ts) and architectural measures.

In practice, these assessments are time-consuming, rely on qualitative judgment, and are performed under uncertainty, particularly in early design phases where architectures and operational constraints are still evolving. At the same time, Large Language Models (LLMs) have demonstrated the ability to generate structured text and to support analytical tasks in cybersecurity, including threat modeling and requirements synthesis [2, 3].

A companion study [4] compared Artificial Intelligence (AI)-generated assessment artifacts to those produced by domain experts for the same system model. A complementary question is how *different* LLMs behave when asked to perform the same IEC 62443-3-2-aligned assessment task under identical conditions. Treating “AI” as a single assessor risks obscuring differences that may stem from model generation, vendor design choices, model capability tier, and stochastic output variability.

This paper therefore adopts an *AI-vs.-AI* perspective: we compare risk assessment artifacts generated by six LLMs for the same ICS case study and task set, focusing on differences in structure, coherence, and practical plausibility rather than on correctness benchmarking.

2 BACKGROUND

This section reviews the technical and methodological foundations: ICS-specific security challenges and the IEC 62443 framework, established risk assessment practice, and the emerging role of LLMs in cybersecurity analysis.

2.1 Industrial Control System Security and IEC 62443

ICSs differ fundamentally from traditional Information Technology (IT) systems due to their tight coupling with physical processes, long operational life cycles, and potentially safety-critical functions. Cybersecurity incidents in ICS environments may therefore lead to physical damage, service disruption, or safety hazards, rather than solely information loss [5, 6]. This perspective is also reflected in established industrial security guidance such as NIST Special Publication 800-82 [7], which emphasizes availability, integrity, and safety over confidentiality in ICS environments.

The IEC 62443 series [8, 9, 1, 10] provides an internationally recognized framework for securing industrial automation and control systems across organizational and technical dimensions. Central to the standard are the concepts of security zones and conduits, which structure system architectures according to trust boundaries and controlled communication paths. IEC 62443-3-2 [1] defines a primarily qualitative (also permitting semi-quantitative) risk-based assessment process for early system design, in which threat scenarios and consequences are used to derive security requirements and target security levels. Resulting security requirements are specified through security levels and foundational requirements in IEC 62443-3-3 [10].

2.2 Risk Assessment in Safety-Critical and Industrial Systems

Risk assessment is a central activity in safety-critical system engineering, supporting early identification and mitigation of unacceptable risks. Cybersecurity risk assessment in ICSs relies heavily on expert judgment due to system heterogeneity, long life cycles, and safety constraints [5]. Standards such as ISO 31000 [11] describe risk assessment as an inherently qualitative process involving uncertainty and expert judgment. In industrial contexts, especially during early design phases, risk assessments are performed on abstract system architectures and rely on assumptions regarding operational conditions and threat exposure.

Prior studies indicate that risk assessments conducted by different experts may yield varying but equally defensible outcomes, even when standardized methods are applied [5]. Risk assessments may therefore admit multiple defensible outcomes depending on assumptions, system interpretation, and expert perspective [12].

In ICS environments, assessment outcomes directly influence architectural decisions such as segmentation, access control, and security level selection. Excessive architectural complexity introduced through risk-driven design can also negatively impact system operability and life cycle cost, highlighting the need for balanced, context-aware risk assessment [6].

2.3 AI-Based Cybersecurity Risk Assessment

Artificial intelligence has been widely studied in cybersecurity, particularly for intrusion detection, vulnerability analysis, and predictive defense systems [13, 14]. Recent advances in LLMs have shown potential for supporting analytical tasks such as threat modeling and structured security analysis [2]. Initial studies suggest that LLMs can affect coverage and consistency in security-related reasoning tasks, although persistent challenges such as hallucination, prompt sensitivity, and limited auditability constrain their use in safety-critical contexts [3].

At the same time, the application of AI-based systems in safety-critical contexts remains constrained by challenges related to interpretability, assurance, and trustworthiness, which have been identified as fundamental AI safety concerns in earlier work [15]. Studies have shown that LLM-assisted code generation can introduce security vulnerabilities into software artifacts [16], while broader LLM-specific attack surfaces, including prompt injection attacks [17, 18] and adversarial manipulations that bypass alignment safeguards [19, 20], raise questions about the integrity of AI-generated artifacts used in security-sensitive workflows. These challenges are particularly relevant in ICSs environments, where security assessments directly inform safety-relevant architectural and design decisions.

Frameworks for systematically mapping AI vulnerabilities to adversarial tactics, such as MITRE ATLAS [21], have been proposed for structuring AI threat taxonomies in critical contexts. A complementary framework, MITRE ATT&CK for ICS [22], provides a structured taxonomy of adversarial tactics and techniques specific to industrial control systems; using it as a systematic coding scheme for comparing LLM-generated threat scenario coverage across models is identified as a direction for future work. However, most existing AI-based cybersecurity research focuses on IT-centric systems or operational security

use cases and does not address the specific constraints of industrial control systems. Moreover, there is limited empirical work evaluating AI-generated analyses and comparing assessment behavior across different models within established industrial standards. In particular, the applicability of LLMs to IEC 62443-3-2-aligned, early-stage ICS risk assessments remains largely unexplored, motivating the comparative study presented in this paper.

3 METHODOLOGY

The study design holds the system description, assessment task, and reporting template constant; each model executes under a single-pass prompting protocol with default inference settings. Observed differences are therefore traceable to model characteristics rather than procedural variation.

3.1 Research Design

The study follows a controlled qualitative comparison design with fixed inputs, a standardized prompting protocol, and a single execution per model. The goal is to characterize how different LLMs structure IEC 62443-3-2-aligned risk assessment artifacts and what architectural implications follow. The independent variables are (i) model generation within a single model family, (ii) model vendor, and (iii) model capability tier (frontier vs. premium-class). The dependent variables are qualitative properties of the generated artifacts, evaluated using pre-defined criteria (Section 3.5).

We executed each model once under default inference settings, mirroring the pragmatic early-stage pattern in which an engineer queries a model to obtain an initial assessment scaffold. The symmetric protocol ensures fair comparison across all models; the methodology is designed so that practitioners can extend it to additional models, systems, or prompt variants.

3.2 System under Consideration

The System under Consideration (SuC) is a fictive tunnel ventilation system described in [4], combining distributed field devices, real-time control, centralized supervision, and direct coupling between cyber integrity and physical safety outcomes. The baseline architecture was intentionally derived from a business-driven (non-security-optimized) design perspective, providing a realistic starting point for risk identification. All models received a single authoritative system description covering two operational use cases:

- Normal air-quality control
- Fire-scenario smoke extraction

These use cases introduce differing consequence severities while maintaining a constant system architecture.

3.3 Assessors

This subsection describes the shared input material, the set of evaluated models with their execution protocol, and the technical details of AI-based assessment execution.

3.3.1 Common Assessment Inputs

To ensure comparability, all models received identical input material without any additional explanations, annotations, or clarifications. The assessment inputs consisted of three documents:

- **System Description** (PDF; converted to inputs/System_Description.txt for machine execution). Describes a fictive tunnel ventilation system, including its functional components, OT/IT connectivity assumptions, and selected operational constraints.
- **Task Description** (PDF; converted to inputs/Task_Description.txt for machine execution). Defines the IEC 62443-3-2-oriented assessment task and expected outputs (threat scenarios, likelihood and consequence estimation, zoning and conduiting, security requirement derivation, and SL-Ts). Also requests assessors to document assumptions and reasoning where necessary.
- **Answer Sheet** (PDF; converted to templates/answer_sheet_template.md for machine execution). Used as the canonical reporting template for all runs.

Converting the PDFs to plain text and Markdown ensured machine-readability and identical textual inputs across models. The task description specifies the organisation’s risk posture (low risk appetite, moderate risk tolerance) in text form but does not provide a numerical risk scoring grid; each model inferred its own scoring scheme from the qualitative description and the 1–5 likelihood/consequence scales in the answer sheet template, representing a potential source of calibration variability. The risk matrix used in the companion human-expert assessment [4] is reproduced in Figure 1. No model was permitted to access external system knowledge beyond the input documents.

		Consequence				
		Negligible (1)	Minor (2)	Moderate (3)	Major (4)	Catastrophic (5)
Likelihood	Almost certain (5)					
	Likely (4)					
	Possible (3)					
	Unlikely (2)					
	Rare (1)					

Figure 1: Risk matrix mapping likelihood (1–5) and consequence (1–5) to four risk levels. Adopted from the companion human-expert assessment [4].

3.3.2 Assessor Set and Run Protocol

The following large language models were evaluated:

- **GPT-4.1** (OpenAI), Axis I baseline
- **GPT-5.1** (OpenAI), Axis I intermediate
- **GPT-5.2** (OpenAI), Axis I target, Axis II participant
- **Claude Sonnet 4.6** (Anthropic), Axis II participant
- **Gemini 3.1 Pro (Preview)** (Google), Axis II participant

- **Claude Opus 4.6** (Anthropic), Axis III premium-tier

The first five models represent frontier-class offerings as designated by their vendors at the time of evaluation. Claude Opus 4.6, positioned by Anthropic as a premium-tier reasoning-optimized model, is evaluated separately in Axis III against the Axis II frontier baseline.

The assessments were conducted in three sessions using GitHub Copilot Chat in a GitHub Codespaces environment: GPT-4.1 and GPT-5.1 on 24 January 2026; GPT-5.2, Claude Sonnet 4.6, and Claude Opus 4.6 on 23 February 2026; Gemini 3.1 Pro (Preview) on 24 February 2026. A single standardized base prompt defined the assessor role, task scope, and output structure. Generated outputs were stored as version-controlled text files with structured metadata.

3.3.3 AI-Based Assessment (Execution Details)

Although the original system documentation and task description existed as PDF files, for machine execution the PDFs were converted to plain text and the answer-sheet template was provided in Markdown. Each model therefore consumed only the prepared text inputs (.txt / Markdown files) and the answer-sheet template, not the original PDF images or figures. Notably, the system description includes an architecture diagram (see [4]) that was not available to any model in image form; each model reconstructed the system topology from the textual component descriptions alone. This conversion was an intentional design choice to evaluate textual reasoning rather than document-image interpretation, but the absence of the architecture diagram may have influenced zone and conduit topology proposals.

The prompting protocol and run procedures are documented in prompts/run_protocol.md; the base prompt used verbatim for all models is available as prompts/base_prompt_v1.md.

Model runs were executed via GitHub Codespaces using GitHub Copilot Chat with default inference settings; no RAG, tool-use extensions, or multi-step refinement were employed. The exact platform-internal prompt orchestration was not transparent to the experimenters and represents an uncontrolled variable shared across all runs (see Limitations).

3.4 Assessment Output Normalization

To enable systematic comparison, all model outputs were normalized into a common analytical structure, including:

- 10 most relevant threat scenarios
- Prioritize the consequence categories
- Estimate the likelihood and consequence
- Define the 10 most appropriate (price vs value) Security Requirements
- Separate the system into Zones and Conduits
- Estimate for each Zone and Conduit an SL-T
- Final System Architecture

This normalization was performed without modifying the substantive content of the assessments.

3.5 Comparative Evaluation Criteria

To compare the LLM-generated risk assessments, task-aligned comparative evaluation criteria were defined, broadly aligned

with the six IEC 62443-3-2 [1] assessment tasks. The criteria assess standards-consistent assessment characteristics, operationalized through consistency, completeness, internal plausibility (relative to other models in this comparison), and alignment with IEC 62443. Given the qualitative nature of IEC 62443 assessments, absolute correctness against an external ground truth is not assumed; multiple defensible assessments may exist depending on assumptions, system interpretation, and expert perspective [12].

Instead of correctness benchmarking, we evaluate artifact quality as a proxy for construct validity, focusing on internal consistency, traceability, and plausibility. Ecological validity is addressed by aligning the experimental protocol with a realistic early-stage engineering workflow in which an assessor produces a first-pass analysis from available documentation.

Assessment outputs were compared along six IEC 62443-3-2 task dimensions, plus the final system architecture as an integrative artifact:

- Threat scenarios (coverage, relevance, specificity)
- Consequence prioritization (consistency, scaling plausibility)
- Risk estimation (coherence, assumption transparency)
- Security requirements (traceability, proportionality)
- Zones and conduits (architectural coherence, zoning-principle consistency)
- SL-Ts (risk-relative plausibility, granularity)

Comparison was conducted as a structured qualitative analysis emphasizing explainability and internal consistency.

Some evaluation dimensions (architectural coherence, operational feasibility, manageability) are inherently normative and reflect established ICS design conventions. The authors applied all normative judgments based on IEC 62443 design principles and ICS engineering practice; evaluator subjectivity is an acknowledged limitation (Section 3.6). The criteria privilege interpretability, operability, and life cycle feasibility over formal risk differentiation.

Architectural coherence was assessed on clarity of trust boundaries, data flow directionality, and placement of security enforcement points at zone and conduit interfaces. A complementary human-expert-vs.-AI comparison is reported in [4].

3.6 Limitations

The study is exploratory and subject to several important limitations that affect interpretation and generalizability.

- **Single-run design and stochasticity.** Each model was executed exactly once under default inference parameters. Consequently, we do not assess run-to-run variability or sensitivity to sampling, temperature, or prompt perturbations. Reported differences therefore reflect single-shot behaviour under the chosen conditions rather than a full characterisation of model variability. All “pattern” statements in the results and discussion sections should be read as observations from this single-run sample; they require replication before any distributional claims can be made.
- **Input modality and equivalence.** Input modality constraints (PDF-to-text conversion, the omission of embedded figures, and notably the absence of the system architecture diagram from model inputs) are described in Section 3.3.3 and apply

uniformly to all models. These constraints were intentional but represent a potential source of output variation, disproportionately affecting zone and conduit topology proposals. The absence of the architecture diagram is a particularly relevant confound for zoning results, as each model reconstructed the system topology from textual descriptions alone.

- **Limited assessor scope.** The AI-based comparisons reflect one prompting protocol and default inference settings per model. Alternative prompting strategies, iterative human-in-the-loop workflows, or different system descriptions may produce substantially different artifacts. Research on adversarial attacks against aligned language models [19, 20] and prompt injection vulnerabilities [17] confirms that LLM output structure and content are sensitive to prompt formulation, raising concerns about the robustness of single-protocol evaluations.
- **No correctness ground truth.** As noted in Section 3.5, multiple defensible IEC 62443 assessments may exist for the same system [12]. Artifact quality is evaluated through structural proxies (internal consistency, traceability, assumption transparency) rather than accuracy against an external standard. Frontier and premium-tier designations reflect vendor marketing classifications and are not independently verified.
- **Evaluator subjectivity.** Normative evaluation dimensions (architectural coherence, operational feasibility) were assessed by the study authors without an independent domain-expert panel. Findings under these criteria represent the authors’ qualified judgment, not objectively verified properties.
- **Deployment context.** All models were accessed via cloud-hosted APIs (GitHub Copilot Chat). In operational ICS environments, air-gap or data-locality requirements may necessitate offline deployments with potentially different artifact characteristics.

These limitations bound the study’s claims: results are hypothesis-generating and require replication. The reproducible methodology (fixed inputs, version-controlled artifacts, structured evaluation framework) supports extension to additional models or repeated runs.

4 RESULTS

This section reports the generated assessment artifacts and their differences across models, structured along the three analytical axes.

4.1 Axis I: Model Evolution Within a Single Model Family (GPT-4.1 vs. GPT-5.1 vs. GPT-5.2)

Three successive GPT generations were evaluated under identical conditions.

4.1.1 Threat Scenario Structuring

All three models identified a broadly consistent set of ten threat scenarios covering the primary attack vectors:

- Remote access exploitation
- Engineering workstation compromise
- Support laptop introduction
- Wireless access point abuse
- Ransomware/malware
- Supply chain attacks via patch management

- Denial of service
- Sensor spoofing
- Physical intrusion

The scenarios are thematically convergent but differ substantially in specificity and contextual grounding.

GPT-4.1 produces generic, high-level descriptions (e.g., “Malware infection of operator workstation or HMI/SCADA, leading to loss of control or false data display”) with brief assumptions and minimal operational context. GPT-5.1 introduces more precise attack paths and operational differentiation (e.g., “Unauthorized remote access via jump host / VPN leading to manipulation of PLC logic or ventilation setpoints”) and links scenarios to both normal and fire operating modes. GPT-5.2 extends this further by naming specific impacted subsystems and consequences (e.g., “fan/damper commands”) and provides richer justification in the comments column.

A notable structural difference is that GPT-5.1 introduces scenario 9 (“Unauthorized or insufficiently controlled changes to PLC application logic”) as a distinct threat separate from the engineering workstation compromise. GPT-5.2 does not separate this but instead includes a corporate/global system status pivot scenario not present in GPT-5.1 or GPT-4.1.

4.1.2 Consequence Prioritization

All three models assign Safety as the highest-priority consequence category. GPT-4.1 and GPT-5.1 share the ordering Safety > Operational (positions 1–2), while GPT-4.1 places Environmental third and Regulatory fourth; the GPT-5.x models invert this, placing Regulatory ahead of Environmental (see Table 1 for the full cross-model comparison). GPT-5.1 provides more specific operational thresholds (e.g., “<5 min loss” vs. GPT-4.1’s “<10 min downtime”). GPT-5.2 mirrors GPT-5.1’s priority ordering and further refines consequence descriptions.

4.1.3 Risk Estimation

Risk score distributions shift across generations (Table 2). GPT-4.1 caps all scenarios at High; both GPT-5.x models introduce a single Critical-risk scenario (score 15), assigned to uncontrolled PLC logic changes (GPT-5.1) and engineering workstation compromise (GPT-5.2) respectively.

4.1.4 Security Requirements

GPT-4.1 provides brief, generic countermeasures (e.g., “Endpoint protection, regular patching”). GPT-5.1 introduces operationally actionable measures with implementation guidance (e.g., “Hardened jump host with strict role-based access control, just-in-time enabling of remote sessions, and continuous security monitoring”). GPT-5.2 extends this with structured zone-based placement of countermeasures and explicit traceability to threat scenarios.

4.1.5 Zoning and Conduit Architecture

All three models converge on a similar zoning concept but differ in granularity. GPT-4.1 defines 3 zones and 3 conduits (total: 6 entities). GPT-5.1 increases this to 6 zones and 3 conduits (9 entities), separating the Field Device Zone, Engineering & Maintenance Zone, and Security / Utility Services Zone. GPT-5.2 produces a near-identical zoning structure to GPT-5.1.

4.1.6 SL-T Assignment

GPT-4.1 assigns SL-T 2–4, with the Control Zone at SL-T 4. Both GPT-5.x models produce SL-T 1–4, introducing SL-T 1 for the Corporate IT Zone and maintaining SL-T 4 for the Control/PLC Zone. The GPT-5.x models additionally assign SL-T 3 to the Security/Utility Services Zone and the Engineering & Maintenance Zone. All three GPT generations assign SL-T 4 to the Control Zone. Architecture narrative depth increases with model generation: GPT-4.1 provides a single-paragraph summary; GPT-5.x adds conduit-specific controls and defence-in-depth rationale.

4.2 Axis II: Cross-Vendor Comparison (GPT-5.2 vs. Claude Sonnet 4.6 vs. Gemini 3.1 Pro)

Three frontier-class models from different vendors were evaluated under identical conditions.

4.2.1 Threat Scenario Structuring

All three models produce ten threat scenarios with substantial thematic overlap. The following themes appear in all assessments:

- Remote access exploitation
- Engineering workstation compromise
- Ransomware
- Supply chain attacks
- Sensor manipulation
- Denial of service

However, structural emphasis and scenario boundaries differ.

GPT-5.2 organizes scenarios around *attack vectors* (how an attacker enters) and maintains a one-to-one mapping between scenarios and system components. Claude Sonnet 4.6 organizes scenarios around *attack objectives* (what the attacker achieves) and includes detailed attacker profiling with references to documented ICS incidents (Stuxnet, SolarWinds, NotPetya, TRITON). Gemini 3.1 Pro takes a more *impact-oriented* approach, organizing scenarios around system functions and their disruption, with a conventional set covering support laptop malware, remote access compromise, DoS, sensor spoofing, ransomware, WAP exploitation, patch management compromise, PLC logic modification, lateral movement from enterprise, and physical tampering with field devices.

Sonnet 4.6 provides the highest technical specificity, naming concrete protocols (S7Comm, EtherNet/IP, Modbus/TCP, CIP Security, OPC-UA) and regulatory frameworks (NIS2 Directive, sector-specific EU safety directives). GPT-5.2 references protocols implicitly through countermeasures. Gemini 3.1 Pro references industrial protocols (Modbus, Profinet) in its assumptions and identifies specific technical conditions (e.g., unencrypted sensor communication) as enablers for attack scenarios.

4.2.2 Consequence Prioritization

All models assign Safety as the highest priority, followed by Operational in second position. The category ordering diverges at positions 3–6; Table 1 shows the full ranking across all six models.

Table 1: Consequence category priority rankings across all evaluated models (1 = highest priority). Divergences from the modal ordering are shown in bold.

Category	GPT-4.1	GPT-5.1	GPT-5.2	Son. 4.6	Gem. 3.1	Op. 4.6
Safety	1	1	1	1	1	1
Operational	2	2	2	2	2	2
Environmental	3	4	4	4	3	4
Regulatory	4	3	3	3	4	3
Reputation	5	5	5	6	5	6
Financial	6	6	6	5	6	5

4.2.3 Risk Estimation

Risk score distributions differ substantially across vendors (Table 2).

Table 2: Risk score calibration profiles across all evaluated models (single run per model; scores = likelihood $\times$ consequence). Range and Mean refer to the $L \times C$ product scores.

Model	Range	Mean	Critical (≥ 15)	High (10–14)
GPT-4.1	8–12	9.7	0	5
GPT-5.1	8–15	10.9	1	7
GPT-5.2	8–15	10.8	1	6
Sonnet 4.6	8–16	11.8	2	7
Gemini 3.1	6–15	10.5	1	7
Opus 4.6	6–12	9.5	0	4

Sonnet 4.6 assigns notably higher likelihoods (multiple $L=4$ for removable media and support laptop threats). GPT-5.2 and Gemini 3.1 Pro show similar moderate profiles with one Critical scenario each (Table 2).

4.2.4 Security Requirements

GPT-5.2 provides well-structured, operationally actionable countermeasures at moderate detail. Sonnet 4.6 delivers the most extensive rationale, with explicit IEC 62443 foundational requirement references (SR numbers) and multi-scenario cross-referencing per countermeasure. Gemini 3.1 Pro provides practical countermeasures with emphasis on access control and device management, including notable recommendations such as physical PLC key switches for program changes, WPA3-Enterprise with certificate-based authentication, and plausibility monitoring in PLCs for detecting sensor and actuator manipulation.

4.2.5 Zoning and Conduit Architecture

The three models produce markedly different zone–conduit topologies:

- GPT-5.2: 6 zones + 3 conduits = 9 entities. Separates AV/Patch Management into its own zone; groups Engineering and Support Laptop together.
- Sonnet 4.6: 4 zones + 4 conduits = 8 entities. Consolidates HMI/SCADA and Engineering Workstation into a single Supervisory Zone (Z3); places the Historian in the DMZ (Z2).
- Gemini 3.1 Pro: 6 zones + 5 conduits = 11 entities. Separates PLC into a dedicated Local Control Zone, field devices into a Field Device Zone, and creates a Temporary/Mobile Zone for the support laptop. Places the Historian in the DMZ alongside the Jump Host and AV/Patch Management.

Gemini 3.1 Pro produces the most granular topology among the Axis II models, separating PLC, field devices, and transient maintenance devices into distinct zones. The most significant divergence concerns Engineering Workstation placement: GPT-5.2 isolates it in a dedicated zone, Sonnet 4.6 groups it with HMI/SCADA in Z3 (recommending sub-zoning), and Gemini 3.1 Pro places it in the Supervisory Control Zone.

4.2.6 SL-T Assignment

The SL-T assignment for the Control/PLC Zone diverges across vendors:

- GPT-5.2: SL-T 4
- Claude Sonnet 4.6: SL-T 3 (with explicit justification that SL-T 4 is not warranted absent confirmed nation-state targeting)
- Gemini 3.1 Pro: SL-T 3

GPT-5.2 is the only model that escalates to SL-T 4 for the Control Zone. Sonnet 4.6 provides a threat-intelligence-based argument for SL-T 3; Gemini 3.1 Pro also assigns SL-T 3 and additionally applies SL-T 3 to the Supervisory Control Zone.

Overall SL-T ranges: GPT-5.2: 1–4; Sonnet 4.6: 1–3; Gemini 3.1 Pro: 1–3. Sonnet 4.6 produces the most complete final architecture with a structured controls summary and Priority 1 residual-risk items; Gemini 3.1 Pro provides a comprehensive narrative with explicit Temporary/Mobile Zone treatment.

4.3 Axis III: Premium-Tier Evaluation (Claude Opus 4.6 vs. Axis II Baseline)

Claude Opus 4.6 was compared as a premium-tier, reasoning-optimized model against the Axis II frontier baseline.

4.3.1 Threat Scenario Structuring

Opus 4.6 produces the most detailed threat scenarios across all models. Each scenario includes protocol-level specificity (OPC-UA, Modbus/TCP, EtherNet/IP, 4–20 mA with digital overlay), explicit attacker motivation analysis, and regulatory context (NIS2 Directive, sector-specific EU safety directives). Uniquely among all models, Opus 4.6 identifies historian data tampering/deletion as a distinct threat scenario (Scenario 10) with explicit forensic and regulatory implications, and separates insider threat as unauthorized operator commands and alarm suppression (Scenario 9) from engineering sabotage.

Compared to the Axis II frontier models, Opus 4.6’s scenarios are qualitatively more granular in their consequence chain reasoning: each scenario traces the attack progression from initial access through intermediate exploitation to final physical/safety impact.

4.3.2 Consequence Prioritization

Opus 4.6’s consequence ordering matches the GPT-5.x/Sonnet 4.6 consensus (Table 1). Its distinguishing feature is operational detail: Safety Level 5 specifies concrete failure modes (“full loss of ventilation control during a fire scenario; evacuation impossible; fire-brigade operations compromised”), and time-based operational thresholds (<10 min through >24 h) are calibrated more granularly than any frontier model.

4.3.3 Risk Estimation

Opus 4.6 shows the most conservative risk calibration across all models (Table 2): no score exceeds 12 and no Critical ratings appear. Distinctively, Opus 4.6 anchors likelihood estimates with quantitative frequencies (“rare: <1 per 10 yrs” vs. “possible: 1–2 per 3 yrs”), unlike any frontier model.

4.3.4 Security Requirements

In this single run, Opus 4.6 produced the most extensive countermeasure rationale across all models. Each of the ten countermeasures cross-references multiple threat scenarios, provides specific implementation technologies (802.1X NAC, SHA-256 verification, WORM mode, Apache Guacamole, EAP-TLS, RADIUS), and includes explicit price-vs-value justification. Notably, Opus 4.6 was the only model to recommend a dual-authorization (four-eyes) principle for safety-critical operator commands, directly linking countermeasure design to the insider threat scenario.

4.3.5 Zoning and Conduit Architecture

Opus 4.6 defines 5 zones + 4 conduits = 9 entities. Notable features include:

- A dedicated **Maintenance Access Zone** (Zone 5) for the support laptop, treated as a separate, lower-trust zone enforced by 802.1X NAC. Among the Axis II frontier models, only Gemini 3.1 Pro similarly creates a dedicated zone for transient maintenance devices.
- A separate **Field/Instrument Zone** (Zone 4) with physically isolated fieldbus, distinguished from the Control Zone.
- Conduit descriptions that specify directional data flow constraints (e.g., “OT→Historian only”) and candidate technologies (data diode, NGFW with OT DPI).

4.3.6 SL-T Assignment

Opus 4.6 assigns SL-T 3 to the Control Zone, consistent with Sonnet 4.6 and Gemini 3.1 Pro but notably *lower* than GPT-5.2’s SL-T 4. Opus 4.6 provides the most detailed SL-T 3/4 decision rationale across all models: “SL-T 4 is not required because there is no confirmed nation-state targeting, and the very low risk tolerance is met at SL-T 3 combined with the countermeasures defined.”

Distinctively, Opus 4.6 applies SL-T 3 to three of four conduits (C1, C2, C4), arguing that conduit SL-T must match or exceed the protection requirements of the zone they guard. This conduit-level SL-T elevation is not observed in any frontier model.

Opus 4.6 also assigns SL-T 2 to the Enterprise Zone (vs. SL-T 1 from Sonnet 4.6 and GPT-5.x), justified by AV/Patch Management residing in that zone.

4.3.7 Final Architecture and Distinguishing Features

Opus 4.6 produces an inside-out architecture description with a nine-category controls summary and, uniquely among all models, an “Unresolved assumptions” section listing four open technical questions (PLC-to-SCADA protocol, SCADA whitelisting compatibility, 802.1X switch support, support laptop access procedures).

5 DISCUSSION

We interpret the results along six dimensions, examining where models converge, where they diverge, and what these patterns imply for practical use.

5.1 Threat Scenario Structure and Consolidation

Across all six models, threat scenario identification converges on a stable core of 7–8 recurrent themes (remote access, engineering workstation, ransomware, supply chain, DoS, sensor manipulation, insider, physical intrusion). Table 3 maps each model’s ten scenarios to a set of canonical themes; the stable core is visible as fully covered columns, while divergences appear in themes that only some models include. This convergence may indicate that contemporary LLMs extract broadly similar attack vectors from a given system description, though convergence may partly reflect shared training data rather than independent analytical agreement.

However, models diverge, sometimes markedly, in how they *structure* and *contextualize* these themes. GPT-4.1 treats scenarios as isolated risk items, with minimal narrative connecting initial access to downstream consequences. The GPT-5.x generation and Sonnet 4.6 introduce attack-chain reasoning, linking initial access to intermediate exploitation steps and final safety impact. Opus 4.6 extends this further by embedding scenarios in regulatory and forensic contexts. Gemini 3.1 Pro takes a conventional, impact-oriented approach that closely aligns with the other frontier models in scenario selection, omitting low-probability edge cases in favour of operationally grounded threats.

The observed outputs suggest a progression from *enumeration* (GPT-4.1) through *contextualization* (GPT-5.x, Sonnet 4.6) to *operational integration* (Opus 4.6).

5.2 Likelihood and Consequence Reasoning

Risk calibration varies substantially across models (see Table 2). Three profiles are discernible:

- Conservative (GPT-4.1, Opus 4.6): compressed range, no Critical ratings. Opus provides explicit quantitative likelihood anchors such as “Rare: <1 per 10 yrs”; GPT-4.1 does not.
- Moderate (GPT-5.1, GPT-5.2, Gemini 3.1 Pro): one Critical scenario each, with qualitative justification.
- Elevated (Sonnet 4.6): two Critical scores at 15–16, justified through documented ICS incident base rates.

Table 3: Scenario coverage by canonical theme across all evaluated models. ✓ = theme present; – = theme absent or subsumed into another scenario.

Theme	GPT-4.1	GPT-5.1	GPT-5.2	Son. 4.6	Gem. 3.1	Op. 4.6	Coverage
Remote access / Jump Host	✓	✓	✓	✓	✓	✓	6/6
Engineering WS / removable media	✓	✓	✓	✓	✓	–	5/6
Support Laptop	✓	✓	✓	✓	✓	✓	6/6
Wireless AP	✓	✓	✓	✓	✓	✓	6/6
Ransomware / malware on HMI	✓	✓	✓	✓	✓	✓	6/6
Supply chain (AV/Patch)	✓	✓	✓	✓	✓	✓	6/6
DoS / network flooding	✓	✓	✓	✓	✓	✓	6/6
Sensor spoofing / tampering	✓	✓	✓	✓	✓	✓	6/6
Insider threat	✓	–	–	✓	–	✓	3/6
Physical intrusion	–	✓	✓	–	✓	–	3/6
PLC logic modification (standalone)	–	✓	–	✓	✓	✓	4/6
Corporate / lateral movement	–	–	✓	–	✓	–	2/6
Historian tampering	–	–	–	–	–	✓	1/6
Credential theft / weak auth	–	–	–	✓	–	–	1/6

These calibration differences have direct practical consequences: a practitioner consuming GPT-5.2 output prioritizes one Critical-risk item; the same practitioner relying on Sonnet 4.6 faces two Critical items demanding immediate treatment. Model choice thus implicitly shapes the urgency and scope of the resulting security programme.

5.3 Zoning and Conduit Granularity

Zoning strategies diverge along two dimensions: *zone count* and *component placement*. Total entity counts range from 6 (GPT-4.1) to 11 (Gemini 3.1 Pro), reflecting different implicit assumptions about appropriate architectural granularity.

Three key placement decisions produce structurally different architectures:

1. **Engineering Workstation:** GPT-5.x isolates it in a dedicated zone; Sonnet 4.6 and Gemini 3.1 Pro group it with HMI/SCADA; Opus 4.6 places it in the Control Zone with the PLC. Isolation requires dedicated conduit controls; co-location implies shared trust boundaries.
2. **AV/Patch Management:** GPT-5.x and Gemini 3.1 Pro favour DMZ-like placement (recognizing the supply-chain amplifier risk); Sonnet 4.6 and Opus 4.6 treat it as a standard enterprise service.
3. **Support Laptop:** Gemini 3.1 Pro and Opus 4.6 both create dedicated zones for transient maintenance devices; other models include the laptop in existing zones.

These placement decisions affect conduit definitions, firewall rule complexity, and day-to-day operational procedures. Zone-conduit design appears to be one of the most model-sensitive aspects of LLM-generated IEC 62443 assessments.

5.4 Security Level Target (SL-T) Escalation Patterns

The most consequential divergence concerns the SL-T assignment for the Control/PLC Zone. All three GPT generations assign SL-T 4, while Sonnet 4.6, Gemini 3.1 Pro, and Opus 4.6 assign SL-T 3. The SL-T 3/4 split aligns with model vendor: OpenAI models escalate to SL-T 4; Anthropic and Google models do not.

Sonnet 4.6 and Opus 4.6 both provide explicit justification for not assigning SL-T 4, arguing that SL-T 4 implies protection against nation-state adversaries with extended resources, and that absent confirmed threat intelligence indicating such targeting, SL-T 3 combined with appropriate countermeasures is sufficient. The GPT models do not discuss this decision boundary.

In practical terms, SL-T 4 implies hardware security tokens, continuous behavioural analytics, and APT resistance, i.e., controls that significantly increase cost and complexity. Assigning SL-T 4 without confirmed nation-state threat intelligence risks over-engineering without proportionate risk reduction. Peripheral zone assignments (Enterprise: SL-T 1–2; Field Devices: SL-T 2) are stable across all models.

5.5 Architectural Coherence and Operational Plausibility

The final architectures span a spectrum from operationally minimal (GPT-4.1: three zones, cursory conduit descriptions) to operationally prescriptive (Opus 4.6: inside-out zone descriptions, technology-specific conduit recommendations, and an “unresolved assumptions” section that treats the assessment as a living artifact). The GPT-5.x models add conduit-specific controls and directional data flow constraints suitable as an implementation starting point. Sonnet 4.6 adds a structured controls summary with explicit Priority 1 residual-risk items. Gemini 3.1 Pro’s 11-entity Purdue-inspired topology and its dedicated Temporary/Mobile Zone independently converge on the same design pattern as Opus 4.6, suggesting zone-level isolation for transient maintenance devices as a robust pattern across vendors.

A cross-cutting observation: more granular zoning implies more firewall rules, access control policies, and maintenance overhead, creating a tension between security granularity and operational manageability that none of the models addresses. Developing coarse-grained complexity proxies (e.g., entity count, conduit interface count) is a direction for future work.

5.6 Premium-Tier vs. Frontier-Class Assessment Behavior

Compared to the frontier baseline, Opus 4.6 stands out in three respects with direct industry relevance:

- It generated an explicit list of unresolved assumptions, a metacognitive feature absent in all frontier models that transforms the assessment from a closed deliverable into a living artifact requiring stakeholder follow-up.
- It maps countermeasures to multiple threat scenarios rather than maintaining one-to-one links, producing a more integrated and auditable control architecture.
- It embeds regulatory context (NIS2 Directive, sector-specific EU safety directives) directly into consequence scaling and SL-T justification, making the artifact more defensible under regulatory scrutiny.

These characteristics matter for procurement and compliance contexts, where traceability and assumption transparency are prerequisites. For preliminary screening, frontier-class models produce adequate threat coverage and architectural recommendations. For assessments that must withstand external review, the additional depth in Opus 4.6's output represents a substantial advantage in completeness and defensibility.

5.7 Implications for Practical Use

The observed differences lead to several implications for practitioners:

1. **Model selection matters:** Model choice influenced risk calibration and SL-T assignments with direct cost implications. The SL-T 3/4 divergence for the Control Zone highlights that LLM outputs require independent review against confirmed threat intelligence.
2. **Multiple models as validation:** Running multiple models on the same input and comparing outputs can reveal areas of consensus (threat scenario themes) and areas requiring expert judgment (zone topology, SL-T calibration).
3. **Premium-tier models for depth:** When artifacts must withstand regulatory scrutiny, premium-tier models produced richer outputs; for initial screening, frontier-class models suffice.
4. **Artifact governance:** LLM-generated risk assessment artifacts should be subject to the same traceability and review requirements as human-authored assessments [23]. The susceptibility of LLMs to prompt injection [17, 18] and adversarial manipulation [19] reinforces the need for integrity controls around the generation process.

6 CONCLUSION

This paper presented a qualitative *AI-vs.-AI* comparison of IEC 62443-3-2-aligned risk assessment artifacts generated by six LLMs under controlled, single-pass conditions. Across three analytical axes (model evolution, cross-vendor differences, and premium-tier comparison) we identified notable differences in threat scenario structuring, zone and conduit design, SL-T assignment, and implied architectural trade-offs. The premium-tier model (Claude Opus 4.6) produced qualitatively richer artifacts than the frontier baseline, with deeper cross-referencing, explicit assumption management, and more granular consequence reasoning.

These findings position LLMs as useful decision-support tools for early-phase IEC 62443 assessments, while emphasizing that outputs are model-dependent artifacts requiring independent

review. Future work should extend this comparison through multi-run evaluations, prompt perturbation studies, and systematic domain-expert validation.

7 DATA AVAILABILITY

All prompts, input documents, generated artifacts, and structured metadata are maintained in a version-controlled repository. The repository structure supports incremental extension with additional models or repeated runs.

8 ACKNOWLEDGEMENT

The authors thank colleagues and collaborators for their technical input and constructive discussions, which helped improve the quality and clarity of this paper.

REFERENCES

- [1] *IEC 62443-3-2: Security for Industrial Automation and Control Systems – Part 3-2: Security Risk Assessment for System Design*, International Electrotechnical Commission (IEC) Standard 62 443-3-2, 2020.
- [2] H. Xu, S. Wang, N. Li, K. Wang, Y. Zhao, K. Chen, T. Yu, Y. Liu, and H. Wang, "Large language models for cyber security: A systematic literature review," *arXiv*, 2025.
- [3] I. Elsharef, Z. Zeng, and Z. Gu, "Facilitating threat modeling by leveraging large language models," in *Workshop on AI Systems with Confidential Computing (AISCC) 2024*, 2024.
- [4] M. Pfister and A. Bernhard, "An exploratory qualitative comparison of human expert and AI-based IEC 62443 risk assessments," *Research Square*, 2026, preprint.
- [5] W. Knowles, D. Prince, D. Hutchison, J. F. P. Disso, and K. Jones, "A survey of cyber security management in industrial control systems," *International Journal of Critical Infrastructure Protection*, vol. 9, pp. 52–80, 2015.
- [6] S. Kriaa, L. Pietre-Cambacedes, M. Bouissou, and Y. Halgand, "A survey of approaches combining safety and security for industrial control systems," *Reliability Engineering & System Safety*, vol. 139, pp. 156–178, 2015.
- [7] *Guide to Operational Technology (OT) Security*, NIST Special Publication 800-82 Revision 3, 2023.
- [8] *IEC/TS 62443-1-1: Security for Industrial Automation and Control Systems – Terminology, Concepts and Models*, International Electrotechnical Commission (IEC) Technical Specification 62 443-1-1, 2009.
- [9] *IEC 62443-2-1: Security for Industrial Automation and Control Systems – Establishing an IACS Security Program*, International Electrotechnical Commission (IEC) Standard 62 443-2-1, 2024.
- [10] *IEC 62443-3-3: Security for Industrial Automation and Control Systems – Part 3-3: System Security Requirements and Security Levels*, International Electrotechnical Commission (IEC) Standard 62 443-3-3, 2013.
- [11] *ISO 31000: Risk Management – Guidelines*, International Organization for Standardization Standard 31 000, 2018.

- [12] T. Aven, “Risk assessment and risk management: Review of recent advances on their foundation,” *European Journal of Operational Research*, vol. 253, no. 1, pp. 1–13, 2016.
- [13] M. Javaid, A. Haleem, R. Singh, and R. Suman, “Significance of artificial intelligence in cybersecurity: A comprehensive review,” *Sensors*, vol. 23, no. 2, p. 820, 2023.
- [14] A. L. Buczak and E. Guven, “A survey of data mining and machine learning methods for cyber security intrusion detection,” *IEEE Communications Surveys & Tutorials*, vol. 18, no. 2, pp. 1153–1176, 2016.
- [15] D. Amodei, C. Olah, J. Steinhardt, P. Christiano, J. Schulman, and D. Mané, “Concrete problems in AI safety,” *arXiv*, 2016.
- [16] H. Pearce, B. Ahmad, B. Tan *et al.*, “Asleep at the keyboard? Assessing the security of GitHub Copilot’s code contributions,” *IEEE Symposium on Security and Privacy*, 2023.
- [17] Y. Liu *et al.*, “Prompt injection attacks and defenses in large language models: A survey,” *arXiv preprint*, 2023.
- [18] OWASP Foundation, “OWASP top 10 for large language model applications,” <https://owasp.org/www-project-top-10-for-large-language-model-applications/>, 2023.
- [19] A. Zou, Z. Wang, J. Z. Kolter, and M. Fredrikson, “Universal and transferable adversarial attacks on aligned language models,” *arXiv preprint*, 2023.
- [20] E. Perez, S. Ringer, K. Lukošiušė *et al.*, “Red teaming language models with language models,” *arXiv preprint*, 2022.
- [21] MITRE Corporation, “MITRE ATLAS: Adversarial Threat Landscape for Artificial-intelligence Systems,” <https://atlas.mitre.org>, 2023.
- [22] —, “MITRE ATT&CK for ICS,” <https://attack.mitre.org/techniques/ics/>, 2025.
- [23] National Institute of Standards and Technology, “Artificial intelligence risk management framework (AI RMF 1.0),” <https://www.nist.gov/itl/ai-risk-management-framework>, 2023.